

Cloud Security Semester Project – Security Monitoring System (AWS)

Student Name: Adiele Chibuike Ambless

Date: February 14, 2026

Account ID (for reference): 672945440489

1. Executive Summary

The objective of this project was to build a real-time security monitoring and alerting system using native AWS services to detect unauthorized access to a honeypot secret stored in AWS Secrets Manager. The system includes two detection flows (CloudWatch Logs + Metric Filter + Alarm, and EventBridge), email notifications via SNS, and an automated active defense kill-switch using Lambda to revoke permissions from the offending IAM user.

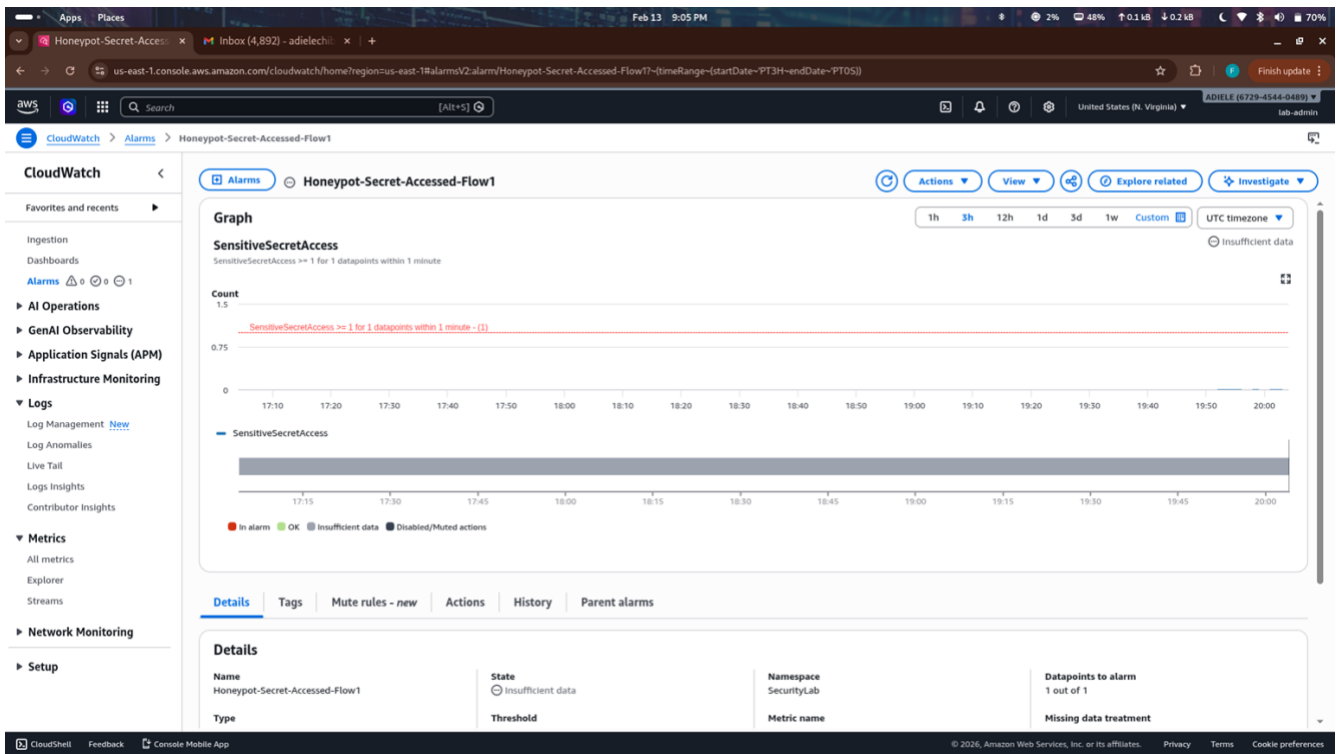
Simulation result: Successful.

A test IAM user (victim-lab-user) accessed the honeypot secret `Production_Database_Credentials`. Both detection flows triggered, SNS notifications were received, and the Lambda function automatically attached an explicit deny-all policy (EmergencyDenyAll) to the user, causing all subsequent AWS actions to fail with `AccessDenied`. This demonstrates effective early detection and automated response to credential misuse or insider threat.

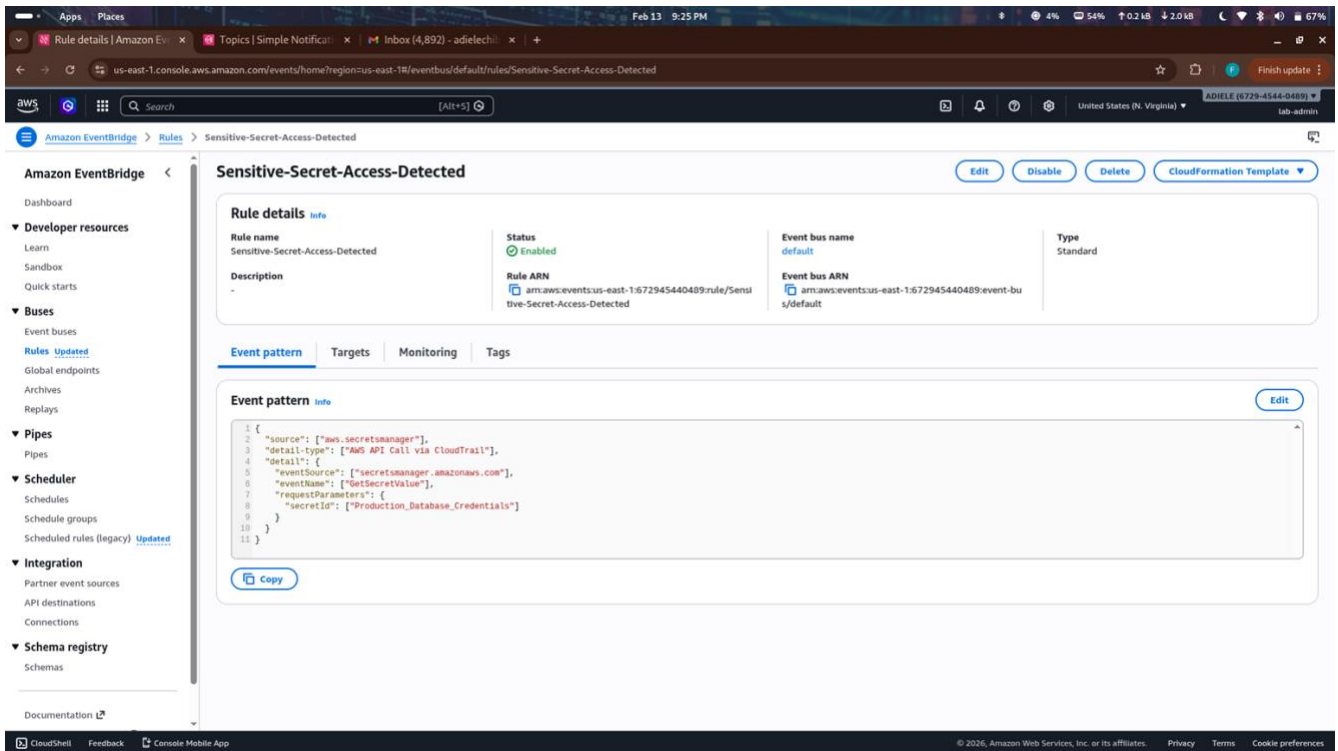
2. Lab Architecture

Overview diagram / description:

Multi-region CloudTrail trail logging management events to CloudWatch Logs → Metric Filter detects `GetSecretValue` on the honeypot → CloudWatch Alarm triggers SNS (Flow 1)
EventBridge rule matches the same event → triggers SNS (Flow 2) and Lambda kill-switch

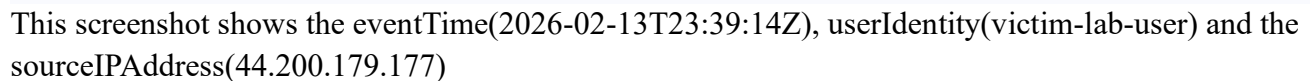


CloudWatch Alarm configuration: "HoneyPot-Secret-Accessed-Flow1"
(showing metric, threshold ≥ 1 in 1 minute, statistic Sum, SNS target)



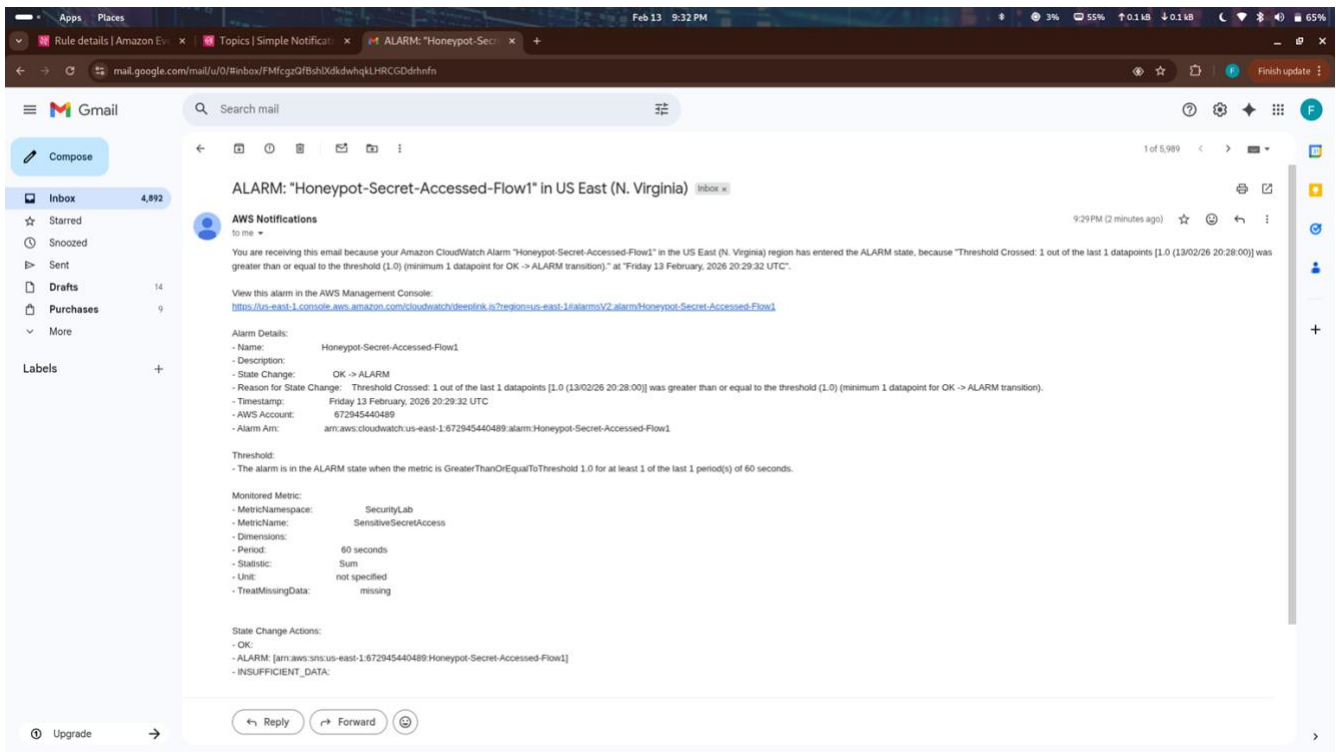
EventBridge Rule details: "Sensitive-Secret-Access-Detected"

CloudTrail event snippet showing the sensitive access (Extracted from the SNS notification JSON email)



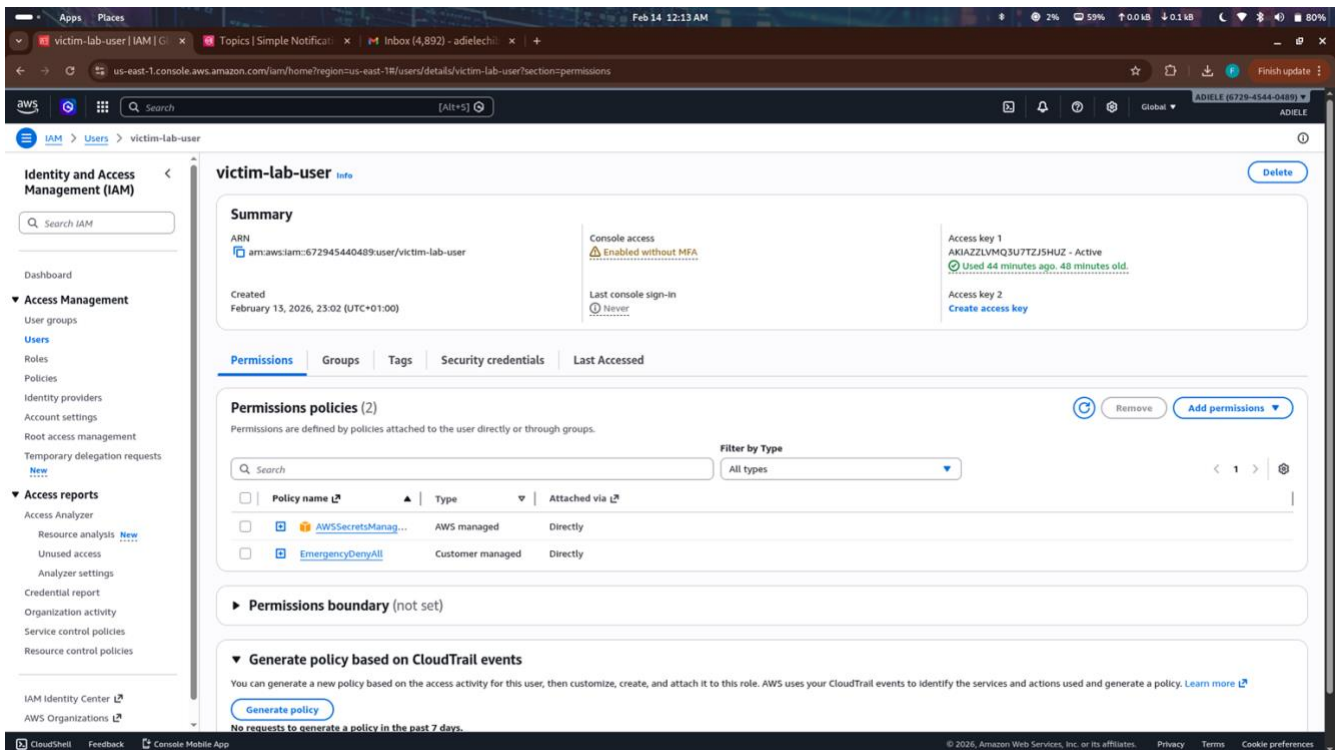
4.1 The Detection

Flow 1 email notification received after access.



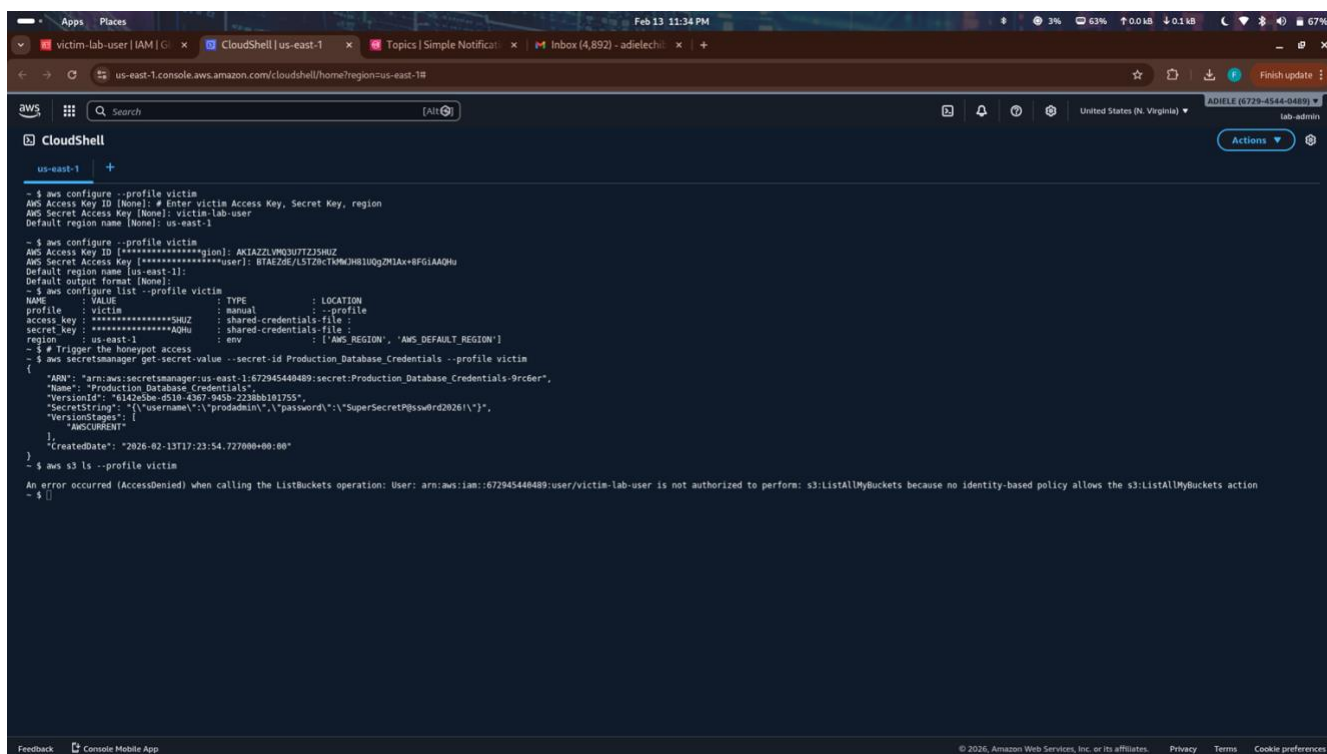
4.2 The "Kill-Switch" Proof

IAM console showing the victim user after the Lambda executed.



4.3 The Log

CloudTrail / CLI evidence of AccessDenied after revocation.



```
- $ aws configure --profile victim
AWS Access Key ID [None]: # Enter victim Access Key, Secret Key, region
AWS Secret Access Key [None]: victim-lab-user
Default region name [None]: us-east-1

- $ aws configure --profile victim
AWS Access Key ID [*****]: AKIAZLVQ3U7TZJ3H6Z
AWS Secret Access Key [*****]: BTAEZ0E/LS7Z8cTKMjH81UgZMIAx+8F6IAAQHu
Default region name [us-east-1]:
Default output format [None]:

- $ aws configure list --profile victim
NAME      : VALUE                                : TYPE      : LOCATION
profile    : victim                                : manual    : -profile
access key : *****596Z                          : shared-credentials-file :
secret key : *****AQHu                          : shared-credentials-file :
region     : us-east-1                             : env       : [AWS_REGION, 'AWS_DEFAULT_REGION']

- $ # Trigger the honeypot access
- $ aws secretsmanager get-secret-value --secret-id Production_Database_Credentials --profile victim
{
  "ARN": "arn:aws:secretsmanager:us-east-1:672945448489:secret:Production_Database_Credentials-9rc6er",
  "Name": "Production_Database_Credentials",
  "VersionId": "6142e3be-d510-4367-943b-2238bb101755",
  "SecretString": "{\"username\":\"prodadmin\",\"password\":\"SuperSecretP@ssw0rd2026!\"}",
  "VersionStages": [
    "AWSCURRENT"
  ],
  "CreateDate": "2026-02-13T17:23:54.727000+00:00"
}

- $ aws s3 ls --profile victim
An error occurred (AccessDenied) when calling the ListBuckets operation: User: arn:aws:iam::672945448489:user/victim-lab-user is not authorized to perform: s3:ListAllMyBuckets because no identity-based policy allows the s3:ListAllMyBuckets action
- $ }
```

5. Security Analysis (The “Spicy” Part)

Speed:

Flow 1 (CloudWatch Metric Filter + Alarm) typically notified after 1–3 minutes due to the 60-second evaluation period + log ingestion delay.

Flow 2 (EventBridge) provided near real-time notification in successful tests (raw event JSON arrived faster in some cases), once the rule was correctly configured to capture read-only events.

Context:

(1) The EventBridge notification (Flow 2) provided significantly more useful forensic information: full CloudTrail event JSON including sourceIPAddress, userIdentity.arn, userName, eventTime, requestParameters.secretId, etc. The CloudWatch alarm email only contained basic threshold information.

(2) To block the user automatically after the alert, the most direct next service is **AWS Lambda** (already implemented) calling IAM APIs (AttachUserPolicy with deny-all or DeleteAccessKey / PutUserPolicy inline deny). Alternatives include adding the user to a quarantine IAM group or using AWS Systems Manager Automation.

Compliance:

This lab satisfies the **Continuous Monitoring** requirement of NIST SP 800-53 (and similar frameworks) through:

- SI-4: Real-time system monitoring via CloudTrail + CloudWatch Logs + EventBridge
- SI-7: Automated detection and response (Lambda kill-switch)

- CM-6 / CM-8: Configuration monitoring and enforcement of least privilege via automated revocation

6. Lessons Learned

If I were to improve and deploy this system in a high-security environment (e.g., a bank), I would **prefer EventBridge (Flow 2)** to trigger the kill-switch action for the following reasons experienced during the lab:

- **Lower latency** — EventBridge is event-driven and near real-time, whereas CloudWatch Metric Filters require a period (minimum 60 seconds) + ingestion delay → critical seconds matter in credential compromise scenarios.
- **Richer context** — Full CloudTrail event JSON is passed directly → easier to extract IP, user ARN, session context, etc., for automated decisions or enriched alerting.
- **Better extensibility** — EventBridge supports multiple targets (SNS, Lambda, Step Functions, etc.) and pattern matching is more flexible than metric filters.

Metric Filter (Flow 1) is still valuable for:

- Aggregation / counting suspicious behavior over time (e.g., 5+ accesses in 5 minutes)
- Simpler setup for basic threshold alerting

Key lessons:

- Read-only API calls like GetSecretValue require the special EventBridge rule state `ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS` — default `ENABLED` skips them.
- Explicit Deny policies are extremely effective (override any Allow) but permanent — in production, consider time-bound revocation, quarantine groups, or approval workflows before permanent changes.
- Testing delays (CloudTrail ingestion 5–30 min) and careful credential management (victim access keys) are critical in labs